

レッドチーミング実施 企画書

1. 背景・目的

背景

現在の医療現場では、電子カルテシステムのベンダーロックインが深刻な社会課題となっている。医療機関ごとに異なるベンダーの電子カルテが導入されており、システム間のデータ連携が困難なため、医療データの流通・二次利用が進んでいない。この結果、医療機関をまたいだ診療情報の共有や、医療データを活用したAI・研究開発が制約されている。

本チームでは、NEDOプロジェクトの一環として、こうした課題を背景に医療データの流通・活用を促進するための基盤技術に取り組んでおり、その一つとして医療特化型LLMシステムの安全性評価を実施している。本プロジェクトでは、医療従事者の診療業務を支援するLLMシステム（以下「本システム」）を想定し、その安全性を評価するための**疑似システム環境を構築**した上で、LLMに対するレッドチーミング（RT）を実施する。なお、本疑似システムは電子カルテシステムとの連携を想定した設計だが、実際の電子カルテシステムとの連携はなく、LLM周辺のみを検証対象とする。

医療分野は患者の生命・身体に直接関わるハイリスク領域であり、AIシステムの安全性確保は極めて重要である。また、本システムは要配慮個人情報である患者の診療情報を取り扱うため、情報セキュリティの観点からも万全の対策が求められる。医療データの流通を推進するにあたって、データを扱うAIシステムの安全性が担保されなければ、医療機関や患者からの信頼を得ることはできない。

このような背景を踏まえ、本疑似システム環境を用いてLLMに対するRTを実施し、潜在的なリスクの特定と対策の有効性評価を行うこととする。

目的

- 本システムに施されたセキュリティ対策及びAIセーフティ対策の有効性を、攻撃者の視点から評価する
- 潜在的な脆弱性を早期に発見し、患者情報の漏洩や誤った医療情報の提供等のリスクを低減する

3. 発見された脆弱性に対する改善策を策定し、システムの安全性向上を図る

2. 対象システム

システム構成の詳細は 01b_システム構成・成果物.md を参照。

システム名称

医療特化型LLMシステム

システム概要

- **主要機能**：診断支援、処方支援、カルテ記載支援
- **利用者**：医師、医療事務などの医療従事者に扮した攻撃者
- **基盤モデル**：API経由で複数のLLMを使用（vLLMによるオンプレミスホスティング、およびOpenRouter経由のクラウドAPI）
- **備考**：模擬構成を想定した設計。実際の電子カルテシステムとの連携はなく、LLMと患者情報DBと監査ログDBのみを備える

3. 実施概要

実施期間

令和7年12月1日 ～ 令和8年3月24日（約16週間）

実施範囲

- LLMへの入力処理
- LLMからの出力処理
- RAG連携部分

実施環境

模擬構成を想定した整理を行うが、検証対象はLLM周辺のみに限定する

RTの種類

ブラックボックステストを基本とし、LLMのモデル内部の解析は行わない

4. 実施体制

01a_チーム体制.md を参照。各役割の責任範囲の詳細は別途策定する実施計画書にて定める。

5. スケジュール（案）

工程	期間	主な実施事項
第1工程	12/1～12/31	実施計画策定、環境準備、体制確立
第2工程	1/1～2/28	リスクシナリオ作成、攻撃シナリオ作成・実施
第3工程	3/1～3/24	結果分析、報告書作成、改善計画策定

6. 概算費用

別途管理とする。

7. 期待される効果

1. 患者安全の向上：誤った医療情報の出力リスクを低減
2. 情報セキュリティの強化：患者情報漏洩リスクの特定と対策
3. コンプライアンス対応：医療情報システムのセキュリティ基準への適合性確認
4. 信頼性の向上：医療従事者及び患者からの信頼獲得